STRIDE ISP 4.3 – PR.DS

Data Security Standards

Version [2.0]

Purpose:

This document defines the Stride standards related to Data Security.

Scope and Applicability

These policies and standards apply to all Stride-owned technology and business operations.

All workforce members and their respective facilities supporting Stride business operations, technology, or both, wherever Stride data is stored or processed, including any third party contracted by Stride to handle, process, transmit, store, or dispose of Stride data are subject to the requirements of this document.

All data, systems, activities, and assets owned, leased, controlled, or used by Stride, its agents, contractors, or other business partners on behalf of Stride are within the scope of the requirements of this document.

The requirements outlined in this document apply where technically feasible and commercially reasonable, as determined by executive management. Any exceptions to these standards must be requested using the approved workflow and remain documented until compliance has been achieved. Exceptions are only granted temporarily for periods of up to one calendar year.

Definitions

All definitions are located within Stride - ISP 1.2 – IT Policy Definitions.

Any inquiries regarding terminology or clarity may be directed to Stride's Information Security Team for assistance.

Publication Owners

Johnny Burns – Point of Contact, Content Coordinator & Author

Jen Havenner – Business Owner

Mark Williams – Executive Sponsor

Document Control

This document may contain proprietary, confidential, or sensitive information owned wholly by Stride Inc. Any distribution of the information contained within this document, in whole or in part, outside of Stride or its subsidiary entities requires the approval of the Executive Sponsor.

This document will be reviewed at least annually and re-issued when revisions are necessary. Any changes introduced in the most recent version are itemized below. Obsolete copies should be destroyed or archived upon the release of the newest version.

Implementation and Compliance

All business units are required to comply with any changes applied to the most recent version of this publication within 90 days from the date of publication.

Change History

Version	Date of Change	Summary of Change(s)
1.0	6/15/2022	Initial Release and Publication
1.1	12/01/2022	- Added Change History - Updated and/or redacted language for clarity where necessary
1.2	03/17/2023	- Updated approvals section
1.3	01/01/2024	- Updated Purpose/Scope/Document Control/Implementation and Compliance - Changed formatting to new standard - Changed document images
1.4	04/24/2024	- Updated data security requirements for testing environments
2.0	01/27/2025	- Major change to align with NIST 2.0 - Updated PR.DS-1, PR.DS-2, PR.DS-3 - Added PR.DS-9, PR.DS-10, PR.DS-11
2.0	03/08/2025	- Published

DATA SECURITY STANDARDS

Policy on Data Security:

Information and records (data) are managed consistently with the organization's risk strategy to protect the confidentiality, integrity, and availability of information.

PR.DS-01: DATA-AT-REST

The confidentiality, integrity, and availability of data-at-rest are protected through robust encryption mechanisms and secure storage practices. Stride prioritizes data security based on the sensitivity and organizational value of the data, as well as the feasibility of implementing security measures.

Standards:

- Encryption methods are implemented that are tailored to the platform and type of data to ensure the protection of sensitive information. The need for encryption may be driven by various factors, including but not limited to:
    - Protecting Personally Identifiable Information (PII), financial data, and other classified information.
    - Complying with standards such as FERPA, HIPAA, and PCI DSS.
    - Encrypting high-risk data to mitigate potential breaches.
    - Securing data transmitted over public or untrusted networks.
    - Encrypting data stored in cloud platforms or shared servers.
    - Enhancing security when access controls are insufficient.
    - Securing offsite or cloud-stored backups.
    - Protecting archived data over extended periods.
    - Encrypting sensitive data shared with partners or vendors.
    - Securing data on laptops and smartphones.
- Stride enforces a minimum encryption standard of AES 256-bit, where technically feasible, to safeguard stored data.
- Encryption methods are validated against documented vendor recommendations and leading industry best practices to ensure robustness and compliance. Examples include:

    - Adhering to NIST guidelines for algorithms such as AES, RSA, and SHA-256. Ensuring secure communications through the enforcement of TLS 1.2 or higher.
    - Avoiding outdated methods like 3DES and migrating to stronger alternatives such as AES-256 or SHA-3.
    - Utilizing hardware security modules (HSMs) for key storage and implementing periodic key rotation.
    - Conducting regular penetration tests and vulnerability scans and using tools like OpenSSL to verify encryption strength and proper configuration.
- Key management and key usage responsibilities are segregated to reduce the risk of unauthorized access or misuse of cryptographic keys.
- Asset custodians, working with data and process owners, are responsible for implementing encryption protocols and processes to meet organizational and regulatory requirements.

References:

- SP 800-218: PS.1.1
- SP 800-218: PS.2.1
- SP 800-218: PS.3.1
- CIS Controls v8.0: 3.11
- CRI Profile v2.0: PR.DS-01
- CRI Profile v2.0: PR.DS-01.01
- CRI Profile v2.0: PR.DS-01.02
- CRI Profile v2.0: PR.DS-01.03
- CSF v1.1: PR.DS-1
- CSF v1.1: PR.DS-5
- CSF v1.1: PR.DS-6

- CSF v1.1: PR.PT-2

PR.DS-02: DATA-IN-TRANSIT

The confidentiality, integrity, and availability of data-in-transit are protected through robust encryption mechanisms and secure transmission practices. Stride prioritizes data security based on the sensitivity and organizational value of the data, as well as the feasibility of implementing security measures.

Standards:

- Encryption methods are implemented that are tailored to the platform and type of data to ensure the protection of sensitive information while it transit. The need for encryption may be driven by various factors, including but not limited to:
    - Protecting Personally Identifiable Information (PII), financial data, and other classified information during transmission.
    - Complying with standards such as FERPA, HIPAA, and others.
    - Encrypting high-risk data to mitigate potential breaches while in transit.
    - Securing data transmitted over public or untrusted networks.
    - Enhancing security when access controls are insufficient.
    - Securing data sent to and received from cloud platforms or shared servers.
    - Protecting sensitive data shared with partners or vendors during transmission.
    - Securing data transmitted to remote locations, including offsite backups and mobile devices.
- Stride enforces a minimum encryption standard of TLS 1.2 or higher, where technically feasible, to safeguard data-in-transit.
- Encryption methods are validated against documented vendor recommendations and leading industry best practices to ensure robustness and compliance. Examples include:

    - Adhering to NIST guidelines for algorithms such as AES, RSA, and SHA-256.
    - Ensuring secure communications through the enforcement of TLS 1.2 or higher.
    - Avoiding outdated methods like SSL 3.0 and migrating to stronger alternatives such as TLS 1.3.
    - Utilizing hardware security modules (HSMs) for key storage and implementing periodic key rotations.
    - Conducting regular penetration tests and vulnerability scans and using tools to verify encryption strength and proper configuration.
- Key management and key usage responsibilities are segregated to reduce the risk of unauthorized access or misuse of cryptographic keys during transmission.
- Asset custodians, working with data and process owners, are responsible for implementing encryption protocols and processes to meet organizational and regulatory requirements for data-in-transit.

References:

- CIS Controls v8.0: 3.10
- CRI Profile v2.0: PR.DS-02
- CRI Profile v2.0: PR.DS-02.01
- CSF v1.1: PR.DS-2
- CSF v1.1: PR.DS-5

PR.DS-05: PROTECTING AGAINST DATA LEAKS

Protections against data leaks are implemented to ensure the confidentiality, integrity, and availability of sensitive information. Stride prioritizes data leak prevention based on the sensitivity and organizational value of the data, as well as the feasibility of implementing security measures.

Standards:

- Data leak prevention measures are implemented to protect sensitive information from unauthorized access, disclosure, or exfiltration. The need for such measures may be driven by various factors, including but not limited to:
    - Protecting Personally Identifiable Information (PII), financial data, and other classified information.
    - Complying with standards such as FERPA, HIPAA, and others.
    - Preventing accidental or intentional data leaks by employees, contractors, or third parties.
    - Implementing access controls to ensure only authorized personnel can access and transmit sensitive data.
    - Utilizing data loss prevention (DLP) tools and techniques to monitor and control data movement.
        - A monitoring capability for internal emails forwarded to unknown email addresses or accounts is established.
        - Data Exfiltration Monitoring is employed on cloud platforms where technically possible and commercially feasible.
    - Encrypting sensitive data to protect it from unauthorized access during transmission and storage.
    - Implementing secure coding practices to prevent vulnerabilities that could lead to data leaks.
    - Conducting regular security awareness training to educate employees on data leak prevention.
- Stride enforces the use of data loss prevention (DLP) tools and techniques, where technically feasible, to safeguard against data leaks.
- Data leak prevention measures are validated against documented vendor recommendations and leading industry best practices to ensure robustness and compliance. Examples include:
    - Adhering to NIST guidelines for data protection and leak prevention.

- Implementing automated monitoring and alerting tools to detect and respond to potential data leaks.
- Ensuring that encryption methods used for data protection are validated against NIST standards (e.g., AES-256).
- Utilizing secure file transfer protocols (e.g., SFTP, FTPS) to protect data during transmission.
- Conducting regular penetration tests and vulnerability scans to identify and mitigate risks related to data leaks.

- Key management and data leak prevention responsibilities are segregated to reduce the risk of unauthorized access or misuse of sensitive information.
- Asset custodians, working with data and process owners, are responsible for implementing data leak prevention protocols and processes to meet organizational and regulatory requirements.

References:

- NIST CSF1.1: PR.DS-5
- NIST Special Publication 800-53r5
- NIST Special Publication 800-53r4
- Cloud Controls Matrix v4.0
- ISO/IEC 27702:2013
- Additional guidance can be found in relevant Center for Internet Security

  Benchmarks at https://www.cisecurity.org/cis-benchmarks
- Stride's Acceptable Use Policy provides clarity on requirements regarding the protection of internal data and proprietary information.
- Forwarding business-related email, intellectual property, or other data owned by Stride to any personal account, personal email address, non-business account, or individual not explicitly authorized for disclosure is prohibited.

- Personal email addresses, accounts, and non-business accounts may include, but are not limited to, email addresses that end in the following:
    - Gmail.com
    - Hotmail.com
    - Live.com
    - Yahoo.com
    - Outlook.com
- Individuals not authorized for explicit disclosure of Stride email, data, intellectual property, or other company-owned assets may include, but are not limited to:
    - Family members
    - Friends
    - The General Public
    - Potential Vendors or Business Associates without Mutual Non-Disclosure Agreements in place.

PR.DS-06: INTEGRITY CHECKING MECHANISMS FOR SOFTWARE

Integrity-checking mechanisms are used to verify the integrity of software, firmware, and information. Stride prioritizes integrity checks based on the sensitivity and organizational value of the data, as well as the feasibility of implementing integrity-checking measures.

Standards:

- Integrity checking mechanisms are implemented to ensure that the integrity of software, firmware, and data is maintained, and any unauthorized changes are detected. The need for such measures may be driven by various factors, including but not limited to:
    - Protecting Personally Identifiable Information (PII), financial data, and other classified information from unauthorized alterations.
    - Complying with standards such as FERPA, HIPAA, and others.
    - Ensuring the authenticity and reliability of software and firmware updates.

    - Implementing cryptographic hash functions to detect unauthorized changes to data.
    - Utilizing digital signatures to verify the integrity and authenticity of software and firmware.
    - Conducting regular integrity checks and audits to identify and address unauthorized modifications.
    - Implementing configuration management practices to maintain the integrity of system settings and files.
    - Using file integrity monitoring (FIM) tools to continuously monitor critical files for changes.
- Software and firmware updates are tested for effectiveness and potential side effects before installation.
    - Reported issues are remediated through patching, rollbacks, or whatever mechanisms are necessary to restore an authorized operating state.
    - Critical and high-priority security-relevant software updates are installed within 30 days of the release of the update.
- Stride enforces the use of integrity-checking mechanisms, where technically feasible, to safeguard the integrity of systems and data.
- Integrity checking measures are validated against documented vendor recommendations and leading industry best practices to ensure robustness and compliance. Examples include:
    - Adhering to NIST guidelines for integrity verification and validation.
    - Implementing automated monitoring and alerting tools to detect and respond to integrity violations.
    - Ensuring that hash algorithms used for integrity checks are validated against NIST standards (e.g., SHA-256).
    - Utilizing secure update mechanisms to verify the integrity and authenticity of software and firmware updates.

    - Conducting regular penetration tests and vulnerability scans to identify and mitigate risks related to integrity violations.

- Key management and integrity checking responsibilities are segregated to reduce the risk of unauthorized access or misuse of integrity verification mechanisms.

- Asset custodians, working with data and process owners, are responsible for implementing integrity checking protocols and processes to meet organizational and regulatory requirements.

References:

- CSF v1.1: PR.DS-6
- NIST Special Publication 800-53r5
- NIST Special Publication 800-53r4
- Cloud Controls Matrix v4.0
- ISO/IEC 27001:2013

PR.DS-07: SEPARATE DEVELOPMENT AND TESTING ENVIRONMENTS

The development and testing environment(s) are separate from the production environment to prevent accidental or intentional interference with live data. Stride prioritizes this separation based on the sensitivity and organizational value of the data, as well as the feasibility of implementing segregation measures.

Standards:

- Separate development and testing environments are maintained to ensure that live data is protected from accidental or intentional interference. The need for such measures may be driven by various factors, including but not limited to:

    - Protecting Personally Identifiable Information (PII), financial data, and other classified information from unauthorized access or modification.

    - Complying with standards such as FERPA, HIPPA, and others.

- Ensuring that development and testing activities do not impact the availability or integrity of production systems.
- Implementing access controls to restrict development and testing environments to authorized personnel only.
- Utilizing network segmentation to isolate development and testing environments from production networks.
- Ensuring that sensitive data is not used in development and testing environments unless properly sanitized or anonymized.
- Implementing change management processes to control the deployment of code from development to production environments.
- Conducting regular audits and reviews to verify the separation of development, testing, and production environments.

- Stride enforces the use of separate development and testing environments, where technically feasible, to maintain the integrity and availability of production systems.
- Separation measures are validated against documented vendor recommendations and leading industry best practices to ensure robustness and compliance. Examples include:
    - Adhering to NIST guidelines for secure software development and testing practices.
    - Implementing automated monitoring and alerting tools to detect and respond to unauthorized access or changes in development and testing environments.
    - Ensuring that development and testing environments are regularly reviewed and updated to reflect changes in production systems.
    - Utilizing secure coding practices and code review processes to minimize the risk of vulnerabilities in production environments.
    - Conduct regular penetration tests and vulnerability scans to identify and mitigate risks related to the separation of environments.

- Key management and separation responsibilities are segregated to reduce risk of unauthorized access or misuse of development and testing environments.

- Asset custodians, working with data and process owners, are responsible for implementing separation protocols and processes to meet organizational and regulatory requirements.

References:

- CSF v1.1: PR.DS-7
- NIST Special Publication 800-53r5
- NIST Special Publication 800-53r4
- Cloud Controls Matrix v4.0
- ISO/IEC 27001:2013

PR.DS-08: INTEGRITY CHECKING MECHANISMS FOR HARDWARE

Integrity checking mechanisms are used to verify and maintain the integrity of hardware components, ensuring that unauthorized changes are detected and addressed.

Standards:

- Integrity checking mechanisms are implemented to ensure that the integrity of hardware components is maintained, and any unauthorized changes are detected. The need for such measures may be driven by various factors, including but not limited to:
    - Protecting hardware components from unauthorized alterations.
    - Complying with standards such as FERPA, HIPAA, and others.
    - Ensuring the authenticity and reliability of hardware updates.
- Hardware updates are tested for effectiveness and potential side effects before installation.
    - Reported issues are remediated through patching, rollbacks, or whatever mechanisms are necessary to restore an authorized operating state.

    - Critical and high-priority security-relevant hardware updates are installed within 30 days of the release of the update.

- Conduct regular integrity checks and audits to identify and address unauthorized modifications to hardware components.

- Implement configuration management practices to maintain the integrity of hardware settings and configurations.

- Utilize file integrity monitoring tools to continuously monitor critical hardware-related files for changes.

- Validate integrity-checking measures against documented vendor recommendations and leading industry best practices to ensure robustness and compliance.

    - Adhere to NIST guidelines for integrity verification and validation.

    - Implement automated monitoring and alerting tools to detect and respond to integrity violations.

    - Ensure that integrity-checking mechanisms are validated against industry standards.

- Segregate key management and integrity-checking responsibilities to reduce the risk of unauthorized access or misuse of integrity verification mechanisms.

- Document the implementation of integrity-checking protocols and processes to meet organizational and regulatory requirements. Ensure that all changes and updates are properly recorded.

References:

- SP 800-53: SI-7

- SP 800-171: 3.3.3

- SP 800-221A: GV.CT-5

- CIS Controls v8.0: 3.8

- CSF v1.1: PR.DS-8

- CSF v1.1: PR.DS-1
- CSF v1.1: PR.DS-6
- CSF v1.1: PR.PT-3

PR.DS-09: INTEGRITY CHECKING MECHANISMS FOR DATA

Implementing integrity checking mechanisms to verify and maintain the integrity of data-at-rest, data-in-transit, and data-in-use, ensuring that unauthorized changes are detected and addressed.

Standards:

- Integrity checking mechanisms are implemented to ensure that the integrity of data-at-rest, data-in-transit, and data-in-use is maintained and any unauthorized changes are detected. The need for such measures may be driven by various factors, including but not limited to:
    - Protecting hardware components from unauthorized alterations.
    - Complying with standards such as FERPA, HIPAA, and others.
    - Ensuring the authenticity and reliability of hardware updates.
- Conduct regular integrity checks and audits to identify and address unauthorized modifications to data.
- Implement configuration management practices to maintain the integrity of data-related settings and configurations.
- Utilize file integrity monitoring tools to continuously monitor critical data-related files for changes.
- Validate integrity-checking measures against documented vendor recommendations and leading industry best practices to ensure robustness and compliance.
    - Adhere to NIST guidelines for integrity verification and validation.
    - Implement automated monitoring and alerting tools to detect and respond to integrity violations.

    - Ensure that integrity-checking mechanisms are validated against industry standards.

- Segregate key management and integrity-checking responsibilities to reduce the risk of unauthorized access or misuse of integrity verification mechanisms.

- Document the implementation of integrity-checking protocols and processes to meet organizational and regulatory requirements. Ensure that all changes and updates are properly recorded.

References:

- SP 800-53: SI-7
- SP 800-171: 3.3.3
- SP 800-221A: GV.CT-5
- CIS Controls v8.0: 3.8
- CSF v1.1: PR.DS-9
- CSF v1.1: PR.DS-1
- CSF v1.1: PR.DS-6
- CSF v1.1: PR.PT-3

PR.DS-10: PROTECTING DATA-IN-USE

The confidentiality, integrity, and availability of data-in-use are protected through robust security mechanisms and practices. Stride prioritizes data security based on the sensitivity and organizational value of the data, as well as the feasibility of implementing security measures.

Standards:

- Security measures are implemented to protect sensitive information while it is actively being processed, manipulated, or used. The need for such measures may be driven by various factors, including but not limited to:

- Protecting Personally Identifiable Information (PII), financial data, and other classified information during processing.
- Complying with standards such as FERPA, HIPAA, and others.
- Securing high-risk data to mitigate potential breaches while in use.
- Implementing access controls to ensure only authorized personnel can interact with sensitive data.
- Utilizing secure coding practices to prevent vulnerabilities during data processing.
- Ensuring secure execution environments for data processing tasks.
- Implementing real-time monitoring and auditing to detect unauthorized access or anomalies during data processing.
- Using data masking and tokenization techniques to protect data-in-use.

- Stride enforces the use of secure execution environments, where technically feasible, to safeguard data-in-use.
- Security measures are validated against documented vendor recommendations and leading industry best practices to ensure robustness and compliance. Examples include:
  - Adhering to NIST guidelines for secure processing practices and environments.
  - Implementing controls to prevent data leakage during processing, such as data masking and encryption.
  - Ensuring that software handling sensitive data is regularly updated and patched to address vulnerabilities.
  - Utilizing hardware security modules (HSMs) for secure key management and storage during data processing.
  - Conducting regular penetration tests and vulnerability scans to identify and mitigate risks in data processing environments.

- Key management and key usage responsibilities are segregated to reduce the risk of unauthorized access or misuse of cryptographic keys during data processing.

- Asset custodians, working with data and process owners, are responsible for implementing security protocols and processes to meet organizational and regulatory requirements for data-in-use.

References:

- CSF v1.1: PR.AC-1
- CSF v1.1: PR.DS-3
- CSF v1.1: PR.IP-1
- CSF v1.1: PR.DS-5
- CRI Profile v2.0: PR.DS-10
- CRI Profile v2.0: PR.DS-10.01

PR.DS-11: BACKUPS

Backups of data are created, protected, maintained, and tested to ensure the availability, integrity, and confidentiality of data in the event of loss or disruption.

Standards:

- Backup mechanisms are implemented to ensure that data is regularly backed up, protected, maintained, and tested. The need for such measures may be driven by various factors, including but not limited to:
    - Protecting data from loss or corruption.
    - Complying with standards such as FERPA, HIPAA, and others.
    - Ensuring the availability and reliability of data backups.
- Datastores are routinely backed up per their uniquely defined frequencies to ensure lost data can be recovered in the event of an incident triggering data loss.

- Ensure that backups are protected at the same level of security as the primary data, including encryption and access controls.

- Conduct regular testing of backups to ensure that they can be successfully restored and that the data integrity is maintained.

- Implement configuration management practices to maintain the integrity of backup settings and configurations.

- Validate backup measures against documented vendor recommendations and leading industry best practices to ensure robustness and compliance.

    - Adhere to NIST guidelines for data backup and recovery.

    - Implement automated monitoring and alerting tools to detect and respond to backup failures.

- Provide alternate sites for storing backups in the event of a disaster or event requiring activation of such a site.

- Document the implementation of backup protocols and processes to meet organizational and regulatory requirements. Ensure that all changes and updates are properly recorded.

- Conduct regular training and awareness programs for relevant stakeholders to ensure they understand their roles and responsibilities in maintaining data backups.

References:

- SP 800-218: PS.3.1

- CIS Controls v8.0: 11.2

- CIS Controls v8.0: 11.3

- CIS Controls v8.0: 11.5

- CRI Profile v2.0: PR.DS-11

- CSF v1.1: PR.IP-4